Introducción a la seguridad de la información

Apuntes teóricos

Alejandro Cajide

I.E.S. San Clemente. Santiago de Compostela

Septiembre de 2026

Índice

1. Fiabilidad, confidencialidad, integridad y disponibilidad **3**
- 1.1. Principios básicos . . . 3
- 1.2. Autenticación y no repudio . . . 3

2. Elementos vulnerables en el sistema informático **4**
- 2.1. Amenaza, vulnerabilidad, riesgo, ataque e impacto . . . 4
- 2.2. Activos de un sistema de información . . . 5
- 2.3. Vulnerabilidades de los principales activos . . . 5
- 2.4. ¿Qué es un hacker? . . . 5

3. Análisis de las principales vulnerabilidades de un sistema informático **6**
- 3.1. Proceso de análisis . . . 6
- 3.2. Herramientas de análisis . . . 6
  - 3.2.1. OpenVAS . . . 7
  - 3.2.2. Nessus . . . 7
  - 3.2.3. CONAN Mobile . . . 7

4. Amenazas y tipos **8**
- 4.1. Amenazas físicas . . . 10
  - 4.1.1. Amenazas físicas y daños asociados . . . 10
- 4.2. Amenazas lógicas . . . 10
  - 4.2.1. Malware . . . 10
  - 4.2.2. Análisis de software malicioso . . . 12
- 4.3. Ejemplos de amenazas . . . 13

5. Seguridad física y ambiental **14**
- 5.1. Objetivos de la protección física . . . 14
- 5.2. Ubicación y protección física de equipos y servidores . . . 15
- 5.3. Sistemas de alimentación ininterrumpida . . . 15
  - 5.3.1. Tipos de SAI . . . 15
- 5.4. Grupos electrógenos . . . 16

6. Seguridad lógica **16**
- 6.1. Objetivos de la seguridad lógica . . . 16
- 6.2. Criptografía . . . 16
- 6.3. Cifrado simétrico . . . 16
  - 6.3.1. Ventajas y limitaciones . . . 17
- 6.4. Cifrado asimétrico . . . 17
- 6.5. Listas de control de acceso . . . 18
- 6.6. Políticas de contraseñas . . . 18
  - 6.6.1. Ataques contra contraseñas . . . 19
- 6.7. Sistemas biométricos de identificación . . . 19
  - 6.7.1. Identificación y verificación . . . 19
- 6.8. Políticas de almacenamiento . . . 20

6.8.1. RAID 0 20
6.8.2. RAID 1 20
6.8.3. RAID 5 21
6.8.4. RAID 6 21
6.8.5. RAID 0+1 21
6.8.6. RAID 1+0 (RAID 10) 21
6.8.7. Resumen comparativo de RAID 22
6.9. Copias de seguridad e imágenes de respaldo 22
6.10. Recuperación de datos 22
6.10.1. Recuperación lógica y física 23
6.10.2. Método Gutmann 23
6.11. Auditorías de seguridad 24
6.11.1. Auditorías completas y parciales 24

7. Análisis forense en sistemas informáticos **24**
7.1. Objetivos del análisis forense 24
7.2. Metodología básica 25
7.3. Recogida y análisis de evidencias 25
7.4. Tipos de evidencias 26
7.5. Herramientas de análisis forense 26
7.5.1. The Forensic Toolkit 26
7.5.2. The Sleuth Kit y Autopsy 27
7.5.3. Herramientas en formato Live 27

Fuente principal **28**

1. Fiabilidad, confidencialidad, integridad y disponibilidad

Un sistema de información se considera seguro cuando cumple unos principios básicos relacionados con la forma en que funciona y con la protección de la información. Destacan cuatro: **fiabilidad, confidencialidad, integridad y disponibilidad**.

1.1. Principios básicos

Fiabilidad El sistema funciona correctamente y realiza las funciones para las que fue diseñado.

Confidencialidad
La información solamente es accesible para las personas autorizadas.

Integridad La información no se altera durante su tratamiento o transmisión, salvo por personal autorizado.

Disponibilidad
El sistema funciona y los usuarios pueden acceder a los componentes que necesitan, de acuerdo con los niveles de seguridad establecidos.

1.2. Autenticación y no repudio

Además de los cuatro principios anteriores, un sistema seguro debe garantizar la **autenticación** y el **no repudio**.

Autenticación
Permite verificar que un documento ha sido elaborado por quien dice ser su autor o que pertenece a esa persona.

No repudio Aporta garantías sobre la autoría y la recepción de la información. En origen, el emisor no puede negar que emitió el mensaje; en destino, se puede acreditar que la información fue entregada al receptor.

El no repudio es especialmente relevante en las transacciones electrónicas, donde interesa disponer de evidencias sobre quién emitió la información y sobre su recepción.

La idea central es que la protección no se limita a impedir accesos: también debe asegurar que la información sea correcta, accesible cuando sea necesaria y atribuible a la entidad correspondiente.

2. Elementos vulnerables en el sistema informático

Una **vulnerabilidad** es la probabilidad o condición que permite que una amenaza llegue a materializarse sobre un activo. Los distintos activos no presentan las mismas vulnerabilidades ni están expuestos a las mismas amenazas.

2.1. Amenaza, vulnerabilidad, riesgo, ataque e impacto

- **Amenaza:** Circunstancia o factor que puede perjudicar al sistema aprovechando una vulnerabilidad.
- **Vulnerabilidad:** Debilidad o condición que puede ser aprovechada por una amenaza.
- **Riesgo:** Posibilidad de que una amenaza llegue a materializarse aprovechando una vulnerabilidad.
- **Ataque:** Materialización de una amenaza.
- **Impacto:** Daño causado sobre el activo como consecuencia del ataque; puede valorarse de forma cualitativa o cuantitativa.



Figura 1: Relación entre amenaza, vulnerabilidad, riesgo, ataque e impacto.

La relación básica es, por tanto, que una amenaza puede aprovechar una vulnerabilidad, materializarse como un ataque y producir un impacto. El riesgo representa la posibilidad de que esto ocurra.

2.2. Activos de un sistema de información

Se diferencia entre **sistema de información** y **sistema informático**. Un sistema de información está constituido por instalaciones, personas, datos y actividades que procesan datos e información en una organización, y puede incluir o no sistemas informáticos.

Entre los activos de un sistema de información se encuentran: Datos, Software, Hardware, Redes, Soportes, Instalaciones, Personal y Servicios.

Un sistema informático está compuesto por: Hardware, Software, Datos y Personal.

2.3. Vulnerabilidades de los principales activos

Personal. Los fallos humanos, tanto intencionados como no intencionados, y la falta de destreza o cualificación pueden constituir vulnerabilidades.

Hardware. Está expuesto a daños eléctricos, robos y desastres que provoquen la destrucción física de los equipos.

Software. Existen vulnerabilidades que permiten ejecutar programas o aplicaciones sin autorización, tanto local como remotamente. También puede haber procesos o programas no deseados que provoquen un mal funcionamiento.

Datos. Deben quedar protegidos frente al acceso de personas o procesos no autorizados. Un dato ya es vulnerable cuando queda expuesto a usuarios no autorizados, aunque no llegue a ser modificado o eliminado.

2.4. ¿Qué es un hacker?

El término *hacker* hace referencia a una persona con amplios conocimientos informáticos, especialmente en el ámbito de los sistemas, las redes y la seguridad. En el contexto de la seguridad informática, un hacker es capaz de descubrir vulnerabilidades en sistemas informáticos y utilizar sus conocimientos para analizar su funcionamiento, detectar errores y desarrollar técnicas de mejora.

El término también se utiliza para referirse a personas expertas en programación y tecnología que buscan resolver problemas, modificar sistemas o superar los límites de una determinada tecnología. Por este motivo, el concepto de *hacker* no implica necesariamente una actividad ilegal o maliciosa.

Es importante diferenciar entre *hacker* y *cracker*. Aunque ambos pueden tener conocimientos suficientes para descubrir vulnerabilidades, el término *cracker* se utiliza para designar a quienes aprovechan estos conocimientos con fines ilícitos o perjudiciales. La asociación

habitual entre *hacker* y delincuencia informática se debe, en parte, al uso que los medios de comunicación han hecho del término.

En el ámbito de la seguridad informática, los hackers pueden tener distintas motivaciones: investigar el funcionamiento de los sistemas, encontrar vulnerabilidades, mejorar su seguridad, superar un reto técnico o, en algunos casos, obtener un beneficio económico o realizar acciones de protesta. Por tanto, el término describe principalmente un nivel de conocimientos y una forma de relacionarse con la tecnología, y no determina por sí mismo que las acciones realizadas sean legales o ilegales.

3. Análisis de las principales vulnerabilidades de un sistema informático

El análisis de vulnerabilidades estudia los componentes del sistema y valora el impacto que podría producir un ataque. Su objetivo es **identificar, evaluar y priorizar** las vulnerabilidades de seguridad.

De forma habitual se emplean herramientas automatizadas para escanear sistemas, especialmente para descubrir puertos abiertos y servicios en ejecución.

3.1. Proceso de análisis

El material propone un proceso compuesto por las siguientes etapas:

1. Identificar los activos del sistema.
2. Identificar las medidas de seguridad existentes.
3. Descubrir las vulnerabilidades.
4. Valorar las posibles amenazas.
5. Establecer los objetivos de seguridad de la organización.
6. Valorar los daños que produciría un ataque.
7. Seleccionar las medidas de protección posibles.

3.2. Herramientas de análisis

El análisis de vulnerabilidades puede realizarse mediante herramientas especializadas que automatizan buena parte del proceso de identificación de problemas de seguridad. Estas herramientas permiten examinar sistemas, dispositivos, aplicaciones y servicios en busca de vulnerabilidades conocidas, configuraciones inseguras, puertos y servicios expuestos u otros indicios de riesgo.

3.2.1. OpenVAS

OpenVAS (Open Vulnerability Assessment Scanner) es un escáner de vulnerabilidades desarrollado y mantenido por Greenbone. Está diseñado para realizar evaluaciones de seguridad sobre sistemas y redes mediante pruebas automatizadas.

Puede realizar tanto pruebas autenticadas como no autenticadas y analizar diferentes protocolos y servicios. Para detectar vulnerabilidades utiliza una colección de pruebas de vulnerabilidad (*Vulnerability Tests*, VT), que se actualiza periódicamente. De esta forma, el escáner puede comprobar los sistemas analizados frente a vulnerabilidades conocidas.

OpenVAS permite realizar análisis sobre diferentes objetivos de red y ajustar la configuración de los escaneos en función de las características del entorno. Los resultados obtenidos permiten identificar vulnerabilidades y otros problemas de seguridad que posteriormente deben ser analizados para determinar su impacto y aplicar las medidas correctoras correspondientes.

Actualmente, OpenVAS forma parte de Greenbone Community Edition, junto con otros componentes de código abierto relacionados con la gestión de vulnerabilidades.

3.2.2. Nessus

Nessus, desarrollado por Tenable, es otra de las herramientas más utilizadas para la evaluación de vulnerabilidades. Su objetivo es identificar problemas de seguridad en sistemas operativos, dispositivos de red, aplicaciones y otros elementos de una infraestructura informática.

Nessus puede detectar vulnerabilidades conocidas, parches que no han sido instalados y configuraciones incorrectas. También permite realizar comprobaciones de configuración, cumplimiento y seguridad, además de generar informes con los resultados obtenidos.

Una característica importante de Nessus es el uso de complementos (*plugins*) que contienen las comprobaciones necesarias para detectar diferentes tipos de vulnerabilidades. Estos complementos se actualizan periódicamente para incorporar nuevas comprobaciones y mantener actualizado el análisis.

Los resultados pueden incluir información sobre la vulnerabilidad detectada, su nivel de riesgo y recomendaciones para su corrección. Nessus también utiliza sistemas de valoración como CVSS y EPSS para ayudar a establecer qué vulnerabilidades deberían recibir mayor prioridad.

3.2.3. CONAN Mobile

CONAN Mobile es una herramienta desarrollada por INCIBE para analizar la seguridad de dispositivos Android. A diferencia de OpenVAS y Nessus, que están orientados principalmente al análisis de infraestructuras y sistemas, CONAN Mobile se centra en dispositivos móviles y, especialmente, en las aplicaciones instaladas.

La herramienta analiza las aplicaciones del dispositivo y comprueba diferentes aspectos relacionados con su seguridad. Entre otras comprobaciones, puede detectar aplicaciones

consideradas maliciosas o sospechosas, revisar los permisos declarados por las aplicaciones y detectar determinadas incidencias relacionadas con sus certificados.

Para determinar si una aplicación puede resultar peligrosa, CONAN Mobile puede comparar el certificado de la aplicación instalada con el disponible en Google Play y comprobar las diferencias existentes en los permisos. También puede utilizar información procedente de diferentes motores antivirus para determinar si una aplicación presenta indicios de comportamiento malicioso.

De esta forma, CONAN Mobile permite obtener una visión general del estado de seguridad y privacidad de un dispositivo Android y detectar aplicaciones que pueden representar un riesgo para el usuario.

En resumen, las tres herramientas tienen ámbitos de aplicación diferentes. OpenVAS y Nessus están orientados principalmente a la evaluación de vulnerabilidades de sistemas, dispositivos, servicios y redes, mientras que CONAN Mobile se centra en el análisis de la seguridad de dispositivos y aplicaciones Android.

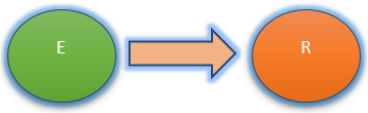
4. Amenazas y tipos

Una amenaza es una circunstancia que puede afectar al sistema aprovechando alguna de sus vulnerabilidades. Se clasifican, en primer lugar, en **amenazas físicas** y **amenazas lógicas**.

También pueden clasificarse según la forma en que interfieren con los datos:

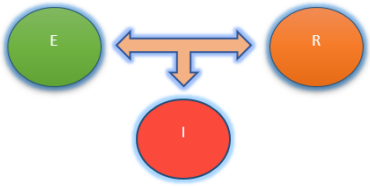
- Interrupción.
- Interceptación.
- Modificación.
- Fabricación.

Flujo normal



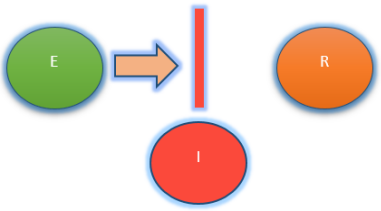
El flujo normal de comunicación es aquel en el que la información es enviada por el emisor al receptor, llegando a su destinatario sin que la información emitida sea accedida ni modificada por ningún intruso.

Intercepción



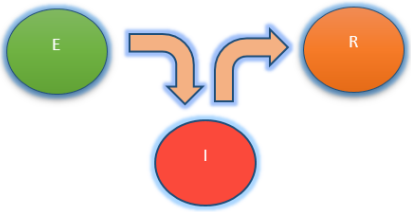
Es un ejemplo de un ataque pasivo en el que se ataca al principio de confidencialidad. En este tipo de ataque el intruso accede a información transmitida por la red, pero en ningún caso se modifica dicha información. En definitiva, el objetivo es capturar información.

Interrupción



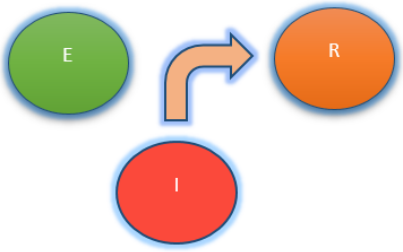
Es un ejemplo de ataque activo en el que se ataca al principio de disponibilidad de un recurso del sistema o de la red, no pudiendo ser usado dicho recurso. Un ejemplo es un ataque de **Denegación de Servicio (DoS)**.

Modificación



Es otro ejemplo de ataque activo en el que se atacan los principios de confidencialidad e integridad. En este caso los datos son modificados en algún momento entre su creación por parte del emisor y su llegada al receptor. Un ejemplo de este tipo de ataque es **ARP spoofing**.

Fabricación



Es otro ejemplo de ataque activo en el que se ataca al principio de autenticación. Se trata de modificaciones destinadas a conseguir que el producto final sea similar al atacado de forma que sea difícil distinguirlo del original. Por ejemplo, el **phishing**.

4.1. Amenazas físicas

Las amenazas físicas pueden ser producidas por personas, de manera accidental o intencionada, o por fenómenos naturales.

Entre las más habituales aparecen: robos, sobatejas, incendios, inundaciones, problemas de temperaturas y humedad, fallos en el sumnistro eléctrico y desastres naturales.

4.1.1. Amenazas físicas y daños asociados

Amenaza	**Descripción**	**Daño posible**
Temperatura del aire	Temperatura inadecuada en salas, armarios de conexiones o equipos.	Fallos de funcionamiento y disminución de la vida útil de los equipos.
Filtraciones de líquidos	Entrada de agua u otros líquidos.	Daños en suelos, cableado y equipos.
Error humano y acceso del personal	Daños involuntarios o accesos no autorizados a las instalaciones.	Daños en equipos, pérdida de datos, robo o sabotaje.
Humo e incendios	Incendios de equipos eléctricos o materiales.	Fallos en equipos y pérdida de bienes y datos.
Calidad del aire	Productos químicos suspendidos y partículas de polvo.	Riesgos para las personas y mal funcionamiento por obstrucción de filtros y ventiladores.

4.2. Amenazas lógicas

Las amenazas lógicas están relacionadas principalmente con el software y con acciones que provocan un funcionamiento incorrecto o no autorizado. Se agrupan entre ellas: *malware, ingeniería social, ataques de denegación de servicio (DoS), ataques de modificación, suplantación, monotorización.*

4.2.1. Malware

El **malware** es software malicioso o no deseado. El material estudia los siguientes tipos o categorías:

- **Bug:** error del software, normalmente asociado a su diseño o desarrollo. Estos fallos pueden aparecer incluso después de realizar pruebas y su corrección suele requerir modificaciones o actualizaciones, comúnmente denominadas **parches**.

- **Caballo de Troya o troyano:** programa que se introduce en el sistema aparentando ser algo atractivo o legítimo para el usuario y que, cuando se ejecuta, produce efectos no deseados. Una vía de contagio mencionada es la descarga de software desde Internet.
- **Backdoor o puerta trasera:** mecanismo que permite el acceso remoto a una máquina sin que el propietario lo detecte. Puede facilitar acciones como borrar ficheros, abrir puertos o acceder a información confidencial.
- **Bomba lógica:** programa que se ejecuta cuando se cumplen determinadas condiciones. Estas condiciones pueden provocar acciones dañinas, como el borrado de archivos o la saturación de servicios.
- **Virus:** código que puede ocultarse en un archivo ejecutable y activarse al ejecutar dicho archivo. El material lo diferencia del troyano atendiendo a su finalidad: el virus se presenta como un elemento destructivo, mientras que el troyano busca principalmente acceder o controlar la máquina sin ser advertido.
- **Gusano:** programa que reside en memoria y puede duplicarse a sí mismo. No necesita la intervención del usuario ni otro fichero para propagarse. Su actividad está relacionada principalmente con el consumo de ancho de banda y recursos del sistema, pudiendo ralentizarlo.
- **Spyware o software espía:** software que recopila información y la envía al atacante sin conocimiento del usuario. Las credenciales pueden ser uno de sus objetivos y puede resultar difícil de detectar.
- **Cookies:** archivos que almacenan información asociada a la navegación de un usuario. Por sí mismas no se consideran software malicioso, pero pueden utilizarse para recopilar o transmitir información sobre los hábitos de navegación.
- **Adware:** software que muestra publicidad y que puede instalarse junto a programas legítimos. Puede recopilar información sobre la actividad del usuario para mostrar publicidad específica y empeorar el rendimiento del equipo.
- **Ransomware:** software que bloquea o secuestra el acceso a equipos o información. Utiliza técnicas criptográficas para cifrar datos y solicitar un rescate a cambio del desbloqueo.
- **Stealer:** software que accede y roba información privada almacenada en el equipo para enviarla al atacante. Entre sus objetivos habituales se encuentran las contraseñas almacenadas en navegadores, el correo electrónico y la mensajería instantánea.

El malware actual puede combinar comportamientos de distintas categorías. Un mismo programa puede actuar como troyano, incorporar características de virus, propagarse como gusano y recopilar información como spyware. Por ello, la clasificación de los programas maliciosos no siempre es estricta.

4.2.2. Análisis de software malicioso

El análisis de software malicioso se realiza en entornos aislados, denominados **cajas de arena o sandbox**, con el objetivo de estudiar su comportamiento sin poner en riesgo el sistema utilizado para el análisis. El aislamiento permite observar las acciones del malware y reducir la posibilidad de que sus efectos se propaguen a otros sistemas.

Existen dos enfoques principales para analizar un programa malicioso:

Análisis estático

Consiste en estudiar el programa **sin ejecutarlo**. Se examinan el código, las instrucciones, las cadenas de texto, las librerías utilizadas y otros elementos del fichero para intentar determinar qué acciones puede realizar. Este tipo de análisis permite obtener información sobre el comportamiento potencial del malware sin activar sus funciones.

El análisis estático puede resultar complejo porque requiere conocimientos especializados y, en muchos casos, el analista únicamente dispone del fichero ejecutable, sin acceso al código fuente original. Por este motivo, el análisis puede requerir examinar cómo está estructurado el programa y qué elementos contiene.

Análisis dinámico

Consiste en **ejecutar el malware en un entorno controlado** y observar las acciones que realiza. Durante la ejecución pueden analizarse los procesos que crea, los cambios que realiza en el sistema, los ficheros que modifica, las conexiones de red que establece y las comunicaciones que mantiene con otros sistemas.

Para reducir los riesgos, el material señala el uso de **máquinas virtuales** como entorno de análisis. De esta forma, el malware puede ejecutarse dentro de un sistema controlado y observarse su comportamiento sin utilizar directamente el equipo habitual del analista.

El análisis dinámico permite conocer el comportamiento real del programa durante su ejecución, aunque los resultados dependen de las condiciones existentes en el entorno de análisis. Un malware puede modificar su comportamiento dependiendo del sistema en el que se ejecuta o de las circunstancias detectadas.

Ambos enfoques son complementarios. El **análisis estático** permite estudiar las características del programa sin ejecutarlo, mientras que el **análisis dinámico** permite comprobar qué acciones realiza realmente durante su ejecución. La combinación de ambos métodos proporciona una visión más completa del comportamiento del software malicioso.

4.3. Ejemplos de amenazas

El material relaciona distintas amenazas con el uso habitual de los sistemas informáticos y de las redes. Aunque se trata de fenómenos diferentes, pueden presentarse conjuntamente en un mismo contexto de seguridad. Entre los ejemplos estudiados se encuentran los siguientes:

Uso indebido de las redes sociales

Las redes sociales pueden utilizarse de forma indebida para obtener o difundir información personal. En este contexto también se consideran los servicios de abreviación de URL y la geolocalización. Los servicios de abreviación permiten convertir una dirección web larga en otra más corta y manejable, pero pueden ocultar el destino real del enlace y utilizarse para redirigir al usuario hacia contenidos maliciosos.

La **geolocalización** permite determinar la ubicación de una persona o dispositivo mediante tecnologías como la red de telefonía, las redes Wi-Fi o el GPS. Aunque puede tener usos legítimos, puede suponer un riesgo para la privacidad cuando la ubicación se comparte sin valorar quién puede acceder a ella.

Uso de dispositivos móviles

Los dispositivos móviles utilizados en entornos empresariales constituyen otro posible ámbito de riesgo, especialmente cuando contienen información corporativa o permiten acceder a servicios de la organización. Su utilización debe tener en cuenta las amenazas derivadas de la pérdida del dispositivo, el acceso no autorizado o la exposición de la información almacenada.

Televisión por Internet

La televisión por Internet constituye otro de los servicios relacionados con el uso de las redes que pueden presentar riesgos de seguridad. El material la incluye entre los ejemplos de amenazas asociadas al uso habitual de las tecnologías de comunicación.

Imitación de legitimidad

Algunas amenazas intentan aparentar ser servicios, comunicaciones o aplicaciones legítimas para conseguir que el usuario confíe en ellas. El material utiliza **Koobface** como ejemplo de este tipo de comportamiento, relacionado con la utilización de redes sociales.

Redes zombies o botnets

Una **botnet** es una red de equipos infectados por malware que pueden ser controlados a distancia sin conocimiento de sus propietarios. El equipo infectado ejecuta un programa denominado *bot* y pasa a formar parte de una infraestructura controlada por un tercero.

Un equipo comprometido puede utilizarse para capturar contraseñas y datos personales, recopilar credenciales de servicios en línea, enviar spam, propagar virus o phishing, participar en ataques DDoS,

manipular encuestas o servicios de publicidad, minar criptomonedas utilizando los recursos del equipo o realizar otros tipos de fraude.

El proceso descrito en el material puede resumirse en cuatro fases: **infección del usuario**, ejecución del bot en el equipo víctima, obtención del acceso a la botnet por parte del atacante y utilización coordinada de los equipos comprometidos para realizar determinadas acciones.

Hackismo o activismo y filtración de información

El **hackismo** o activismo mediante medios informáticos puede utilizarse para publicar o difundir información. El material utiliza **Wikileaks** como ejemplo de publicación de información, destacando el riesgo que supone que una persona con acceso a información confidencial pueda utilizar medios de publicación abiertos para hacerla pública.

Amenazas persistentes avanzadas (APT)

Las **APT** (*Advanced Persistent Threats*) son ataques planificados y persistentes orientados, entre otros objetivos, al robo de información. El material utiliza la "Operación Aurora" como ejemplo de una cadena de acciones que comienza con un mensaje atractivo, continúa con la ejecución de un programa que facilita el acceso remoto y termina con el acceso del atacante al equipo y la copia de información.

Stuxnet

Stuxnet se presenta como un gusano capaz de reprogramar sistemas industriales. El ejemplo permite observar cómo una amenaza informática puede dirigirse contra infraestructuras industriales y afectar a instalaciones cuyo funcionamiento depende de sistemas informáticos.

5. Seguridad física y ambiental

La seguridad física y ambiental establece medidas para evitar accesos no autorizados, daños e interferencias que afecten a los sistemas de información. Las zonas restringidas deben quedar reservadas a personal autorizado y deben mantenerse las condiciones ambientales necesarias para el funcionamiento correcto de los equipos.

5.1. Objetivos de la protección física

La protección física se orienta principalmente a prevenir daños provocados por: Personal no autorizado, Agua, Fuego, Temperatura, Suciedad y Fallos en el suministro eléctrico.

Para proteger los equipos hay que elegir una ubicación adecuada, considerando:

- La construcción del edificio y de las salas.
- La protección frente a incendios, inundaciones y terremotos.

- La temperatura, la humedad y la calidad del aire.

5.2. Ubicación y protección física de equipos y servidores

Un servidor puede almacenar datos y aplicaciones compartidas y, por ello, constituye un elemento especialmente importante dentro de una instalación.

La ubicación de equipos y servidores debe:

- Ser lo más inaccesible posible para usuarios no autorizados.
- Reunir condiciones geográficas adecuadas frente a catástrofes naturales.
- Mantener unas condiciones ambientales que garanticen el funcionamiento.

El material utiliza el concepto de **sala fría** para referirse a una sala destinada a los equipos que almacenan los datos, separada de otras dependencias de control y con mecanismos de control de acceso.

5.3. Sistemas de alimentación ininterrumpida

Un **SAI** (sistema de alimentación ininterrumpida) proporciona corriente eléctrica a partir de un acumulador u otra fuente de energía cuando falla el suministro normal.

Las partes básicas de un SAI son:

Rectificador Convierte corriente alterna en tensión continua para cargar la batería.

Baterías Almacenan la energía utilizada durante un corte.

Convertidor Convierte la tensión continua de las baterías en tensión alterna.

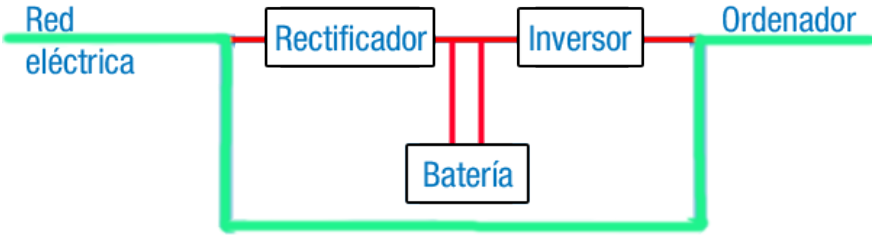


Figura 2: Partes principales de un SAI: rectificador, Batería e Inversor.

5.3.1. Tipos de SAI

Offline o standby. Es el tipo más extendido en equipos domésticos. Entra en funcionamiento cuando falla la red, pero existe un intervalo apreciable y ofrece una protección más limitada frente a perturbaciones.

Online. Se intercala entre la red y la carga. La salida se genera a partir de la corriente almacenada en las baterías y existe aislamiento entre la carga y la red normal, ofreciendo una protección mayor frente a anomalías.

Interactivo o line-interactive. Es una solución intermedia. No aísla completamente la carga de la red, pero protege frente a fluctuaciones dentro de unos márgenes y el tiempo de transición es del orden de milisegundos.

5.4. Grupos electrógenos

Los grupos electrógenos proporcionan electricidad a partir de una fuente de energía distinta de la eléctrica. El material destaca el uso de motores de combustión para generar energía mecánica que posteriormente se transforma en energía eléctrica.

6. Seguridad lógica

La seguridad lógica complementa a la seguridad física y busca impedir o paliar los daños derivados de amenazas lógicas. Se centra en proteger el software, las aplicaciones y los datos de los usuarios.

6.1. Objetivos de la seguridad lógica

- Dificultar el acceso no autorizado a programas, archivos y datos.
- Conseguir que la información transmitida llegue únicamente al destinatario previsto.
- Verificar que la información recibida coincide con la transmitida.
- Habilitar sistemas alternativos de transmisión o almacenamiento.
- Establecer medidas de análisis que permitan mejorar el funcionamiento del sistema.

6.2. Criptografía

La criptografía permite proteger la información de una comunicación mediante algoritmos y claves. Se distinguen dos grandes familias: **sistemas simétricos** y **sistemas asimétricos**.

6.3. Cifrado simétrico

En los sistemas simétricos, el emisor y el receptor utilizan la **misma clave** para cifrar y descifrar.

El funcionamiento se basa en un secreto compartido que ambas partes deben conocer.



Figura 3: Esquema de la criptografía simétrica.

6.3.1. Ventajas y limitaciones

La principal ventaja indicada es la **rapidez del cifrado y descifrado**, por lo que resulta adecuado para grandes volúmenes de datos.

Las principales dificultades son:

1. **Intercambio de claves**: las partes necesitan disponer previamente de la misma clave y surge el problema de cómo transmitirla de forma segura.
2. **Gestión de claves**: cuando participan muchas entidades, aumenta el número de claves que deben almacenarse y gestionarse.

6.4. Cifrado asimétrico

Los sistemas asimétricos utilizan una **pareja de claves**: una pública y una privada.

- La **clave pública** puede distribuirse a otras entidades.
- La **clave privada** debe mantenerse secreta.

En este tipo de criptografía, el emisor cifra el mensaje con una de las claves y debe conseguir que el receptor utilice la otra para descifrarlo. Por tanto, en este tipo de criptografía, cada una de las partes involucradas en una comunicación segura tienen una pareja de claves. Una de ellas, pública, que deberá intercambiar con cada una de las entidades con las que quiera comunicarse, y la otra privada, y que por tanto, jamás debe comunicarse a nadie. A pesar de que la pública se le comunica a todo el mundo, no se crea una vulnerabilidad en las comunicaciones porque con ella, un intruso nunca podría descifrar el mensaje.

Estas claves se generan a la vez y se encuentran relacionadas matemáticamente entre sí mediante funciones de un solo sentido. Se aprovechan propiedades matemáticas particulares que hacen que su computación sea fácil, mientras que su inversión resulta extremadamente difícil. Por tanto, resulta prácticamente imposible descubrir la clave privada a partir de la pública. **La seguridad debe impedir que conociendo una de ellas se descubra la otra**.

El auge de las conexiones a través de Internet y la necesidad de encriptar la información transmitida han hecho que aparezcan varios métodos basados en estos criptogramas. Entre ellos se pueden destacar:

- **Firma digital y firma electrónica:** La firma electrónica es una firma digital que se ha almacenado en un soporte hardware, mientras que la firma digital se puede almacenar tanto

en hardware como en software. Una firma electrónica es más segura que una firma digital porque no se puede modificar. Ambas tienen la misma validez y cometido, identificar al emisor o al receptor en una comunicación y su uso no implica que la información transmitida esté encriptada. Por ejemplo, la firma electrónica se encuentra dentro del DNI electrónico, aunque firmar algo con el DNI electrónico no implica encriptarlo.

- **Certificado digital:** poseen una clave pública visible y otra privada que permanece secreta y que ha sido proporcionada por la entidad emisora del certificado al constatar que la persona (física o jurídica) es quien dice ser. La clave privada se incluye en el certificado pero el usuario no la puede ver.
- **Certificado electrónico:** es un documento electrónico que identifica a una persona. Según la ley de firma electrónica 59/2003, un certificado electrónico es un documento firmado electrónicamente por un prestador de servicios de certificación que vincula unos datos de verificación de firma (clave pública) a un firmante y confirma su identidad

6.5. Listas de control de acceso

Las **ACL** (*Access Control Lists*) son registros que determinan qué usuarios pueden acceder a un recurso y qué privilegios tienen.

En un router, una ACL puede controlar el tráfico que atraviesa sus interfaces. Las reglas pueden utilizar, por ejemplo, direcciones IP para permitir o denegar determinados paquetes.

También existen ACL aplicadas a permisos de archivos y procesos.

En sistemas Linux, el material diferencia las ACL de los permisos tradicionales gestionados con `chmod`. Estos últimos permiten establecer permisos para el propietario, el grupo y otros usuarios, mientras que las ACL proporcionan un control más específico.

6.6. Políticas de contraseñas

La contraseña es uno de los métodos más utilizados para controlar el acceso a procesos, ficheros, datos y recursos.

La seguridad de una contraseña depende especialmente de:

- El secreto de la contraseña.
- Su fortaleza o dificultad para ser descubierta.

Recomendaciones para las contraseñas:

- Utilizar una longitud suficiente; se menciona un mínimo de 8 caracteres y como objetivo 14 o más.
- Combinar letras mayúsculas y minúsculas, números y símbolos.
- Evitar fechas, nombres propios y palabras conocidas.

- No relacionar la contraseña con el usuario.
- Evitar secuencias y caracteres repetidos.
- No utilizar el nombre de inicio de sesión.
- No utilizar palabras de diccionario.
- Utilizar contraseñas diferentes en distintos entornos.
- Evitar contraseñas en blanco.
- No revelar la contraseña ni introducirla en equipos que no se controlan.
- Cambiar las contraseñas con regularidad.

6.6.1. Ataques contra contraseñas

Fuerza bruta. Prueba combinaciones hasta conseguir descubrir la contraseña. El tiempo necesario depende de su estructura y complejidad.

Ingeniería social o phishing. Busca engañar al usuario para que entregue la contraseña.

Keylogger. Registra las teclas pulsadas para obtener credenciales.

Ataque de diccionario. Utiliza listas de contraseñas habituales y las prueba de manera secuencial.

6.7. Sistemas biométricos de identificación

Los sistemas biométricos identifican a las personas mediante características biológicas. El material los define como sistemas capaces de medir, codificar, comparar, almacenar, transmitir o reconocer determinadas características con un grado de precisión y fiabilidad.

Entre las características biométricas citadas aparecen: iris, voz huella dactilar, fisonomía facial, forma de mane, forma de andar, tensión sanguínea, temperatura corporal, etc.

6.7.1. Identificación y verificación

Identificación. Se extraen los datos significativos de una persona y se genera un *template* que se almacena en la base de datos.

Verificación. Se comparan los datos presentados por la persona con los almacenados. Si la comparación es positiva, se permite el acceso.

Un ejemplo podría ser la huella dactilar y el iris. En ambos casos, la característica física se transforma en una representación digital que puede utilizarse para comparar la identidad.

Los sistemas biométricos no se consideran totalmente seguros, ya que pueden existir mecanismos para falsearlos. Por este motivo se investiga la utilización de características y técnicas de reconocimiento adicionales.

6.8. Políticas de almacenamiento

El almacenamiento de la información debe estar centralizado y organizado para facilitar su gestión. Las políticas de almacenamiento buscan aumentar la **tolerancia a fallos** y la **seguridad**.

RAID agrupa técnicas hardware o software que utilizan varios discos para proporcionar, según la configuración, tolerancia a fallos, mayor capacidad, disponibilidad, rendimiento y seguridad.

Sus beneficios principales son:

- Mayor capacidad al combinar varios discos.
- Mayor disponibilidad ante determinados fallos.
- Mayor seguridad y garantías sobre la integridad de los datos.
- Mayor velocidad en configuraciones que permiten operaciones simultáneas.

6.8.1. RAID 0

Distribuye los datos entre dos o más discos. Favorece el rendimiento porque las operaciones pueden realizarse simultáneamente.

No utiliza información redundante: **si falla uno de los discos, se pierde la información de la unidad**. Por tanto, se orienta al rendimiento más que a la tolerancia a fallos.

6.8.2. RAID 1

También denominado espejo. Mantiene una copia idéntica de la información en dos o más discos.

Características principales:

- La capacidad útil es la del disco más pequeño.
- Si falla un disco, el sistema puede seguir funcionando con el otro.
- El espacio útil se reduce aproximadamente a la mitad cuando se utilizan dos discos iguales.
- Puede ofrecer un buen rendimiento de lectura.
- La escritura es algo más lenta porque debe realizarse en todos los discos.

6.8.3. RAID 5

Distribuye los bloques de datos y la información de paridad entre todos los discos del conjunto.

Para un conjunto de N discos, la capacidad útil es la suma del espacio de los discos menos el equivalente a un disco. Si falla un disco, la información puede recuperarse mediante la paridad distribuida.

El material señala que **si fallan dos discos simultáneamente, la información resulta irrecuperable**.

6.8.4. RAID 6

Utiliza dos bloques de paridad distribuidos entre los discos. Requiere al menos cuatro unidades y puede soportar el fallo de dos discos.

Su principal ventaja respecto a RAID 5 es la mayor tolerancia a fallos. Como contrapartida, las escrituras son más lentas por el cálculo de la paridad adicional y la capacidad útil es la correspondiente a $N - 2$ unidades.

6.8.5. RAID 0+1

Primero se crean dos conjuntos RAID 0 y, posteriormente, se realiza un espejo RAID 1 sobre ellos.

Ofrece tolerancia a fallos, pero es menos robusto que RAID 10. Según el material, un segundo fallo puede comprometer todo el conjunto dependiendo de la división afectada.

6.8.6. RAID 1+0 (RAID 10)

Es un conjunto de espejos sobre los que se realiza una división de datos. El material lo presenta como una alternativa especialmente adecuada para bases de datos que necesitan altas prestaciones.

Al no requerir cálculos de paridad, puede ofrecer un buen rendimiento de escritura. No obstante, si no se sustituyen discos averiados, un único disco restante en un espejo puede convertirse en un punto único de fallo.

6.8.7. Resumen comparativo de RAID

Nivel	Idea principal	Tolerancia	Capacidad útil	Enfoque
RAID 0	Distribución de datos	Ninguna	Suma de discos	Rendimiento
RAID 1	Espejo	Fallo de un disco en un espejo	Aproximadamente la mitad	Redundancia
RAID 5	Datos + paridad distribuida	Fallo de un disco	$N - 1$	Equilibrio
RAID 6	Datos + doble paridad	Fallo de dos discos	$N - 2$	Alta tolerancia
RAID 0+1	RAID 0 espejado	Dependiente de la distribución de fallos	Menor que RAID 0	Rendimiento + redundancia
RAID 10	Espejos sobre los que se distribuyen datos	Elevada frente a fallos adecuados	Menor que RAID 0	Rendimiento + redundancia

6.9. Copias de seguridad e imágenes de respaldo

Las copias de seguridad permiten restaurar información después de pérdidas provocadas por incendios, variaciones eléctricas, robos u otros fallos. Se relacionan directamente con la **integridad y disponibilidad** de la información.

Soportes: Cintas magnéticas, CD y DVD, Memorias USB, Discos duros portátiles, Servidores externos.

Tipos de copia:

Completa Copia todos los archivos seleccionados.

Diferencial Copia los archivos creados o modificados desde la última copia completa.

Incremental Copia los archivos modificados desde la última copia completa o diferencial.

Las copias deben priorizar la información más importante y, cuando haya que elegir, aquellos archivos que sean más difíciles de reemplazar.

Una mala práctica es guardar la copia en el mismo equipo o disco del que procede. El material recomienda utilizar dispositivos externos y evitar que una copia quede expuesta al mismo incidente que el sistema original.

6.10. Recuperación de datos

La recuperación de datos consiste en aplicar técnicas sobre un dispositivo dañado para extraer la información que todavía puede recuperarse. La dificultad depende de la naturaleza del daño y no siempre es posible recuperar todos los datos.

6.10.1. Recuperación lógica y física

Recuperación lógica
: Utiliza software especializado para intentar recuperar información o estructuras de archivos.

Recuperación física
: Interviene sobre el soporte de almacenamiento cuando existe un daño físico. Las técnicas dependen de la tecnología utilizada.

En los discos magnéticos, el material menciona el uso de microscopios de fuerza magnética (MFM) como ejemplo de técnica de análisis físico.

También se estudia la necesidad de destruir la información cuando un soporte se considera obsoleto. Entre los métodos aparece el **método Gutmann**, basado en la sobrescritura de los datos para dificultar su recuperación.

6.10.2. Método Gutmann

El **método Gutmann** es una técnica de borrado seguro de información basada en la sobrescritura de los datos almacenados en un dispositivo. Su finalidad es dificultar o impedir la recuperación posterior de los datos que han sido eliminados.

El procedimiento consiste en realizar varias pasadas de sobrescritura sobre la zona del dispositivo donde se encontraba almacenada la información. En cada pasada pueden utilizarse diferentes patrones de datos, de manera que la información original quede progresivamente reemplazada por otros valores.

La técnica fue propuesta por Peter Gutmann y está especialmente relacionada con los discos magnéticos. El método original contempla un conjunto de **35 pasadas** de sobrescritura, utilizando diferentes patrones. Las primeras y últimas pasadas emplean patrones específicos, mientras que otras pasadas utilizan secuencias de datos destinadas a dificultar la recuperación de la información mediante técnicas de análisis de los restos magnéticos.

El objetivo del método no es simplemente marcar los archivos como eliminados, sino **sobrescribir físicamente la información** para reducir las posibilidades de recuperar los datos originales. Esto es importante porque eliminar un archivo mediante los mecanismos habituales del sistema operativo no implica necesariamente que sus datos desaparezcan inmediatamente del dispositivo.

El número de pasadas hace que el proceso pueda resultar considerablemente más lento que un borrado convencional. Además, la utilidad de aplicar las 35 pasadas originales depende del tipo de dispositivo y de la tecnología de almacenamiento utilizada. El método Gutmann fue diseñado principalmente teniendo en cuenta determinadas características de los discos magnéticos, por lo que no todas sus pasadas tienen el mismo sentido en dispositivos modernos.

Por tanto, el método Gutmann debe entenderse como una técnica de **borrado seguro mediante sobrescritura**, cuyo propósito es dificultar la recuperación de información que ya no debe permanecer accesible.a.

6.11. Auditorías de seguridad

Una auditoría de seguridad es una revisión del estado de los sistemas de seguridad de un sistema informático. Puede realizarse aunque el sistema funcione correctamente, con el propósito de comprobar su estado o detectar vulnerabilidades antes de que se produzca un incidente.

Las auditorías deben ser realizadas por personal cualificado y, en la medida de lo posible, independiente de la organización auditada.

Estándares citados:

- COBIT.
- ISO 27002.
- ISO 27001.

6.11.1. Auditorías completas y parciales

Auditoría completa. Analiza todos los componentes del sistema, incluyendo usuarios, instalaciones, hardware, software y aplicaciones. Es la opción más exhaustiva, pero también la más costosa.

Auditoría parcial. Se centra únicamente en la parte del sistema donde existe una sospecha o necesidad concreta, por ejemplo las instalaciones cuando se sospechan problemas relacionados con el hardware.

7. Análisis forense en sistemas informáticos

El análisis forense informático estudia un incidente de seguridad para reconstruir lo ocurrido y obtener evidencias. El material lo relaciona con la idea de conservar el escenario de un incidente para evitar contaminar las evidencias.

7.1. Objetivos del análisis forense

Los objetivos principales son:

- Recrear lo sucedido durante el incidente.
- Analizar las incidencias para evitar que vuelvan a producirse.

Un análisis puede considerarse completo cuando se conoce:

- Cómo se produjo el incidente.
- En qué circunstancias ocurrió.

- Quiénes fueron los atacantes.
- Cuándo ocurrió.
- Cuáles eran los objetivos de los atacantes.
- Qué evidencias demuestran lo ocurrido.

Hay que insistir en que la información investigada no debe dañarse y que, cuando sea posible, se trabaja sobre copias en lugar de sobre los originales.

7.2. Metodología básica

El proceso descrito comprende:

1. Analizar el funcionamiento del sistema para extraer información.
2. Respetar el marco legal.
3. Recopilar las evidencias posibles.
4. Autenticar las evidencias.
5. Protegerlas para evitar alteraciones y trabajar sobre copias.
6. Analizar las evidencias.
7. Elaborar un informe final detallado.
8. Destruir la información duplicada cuando sea necesario.

7.3. Recogida y análisis de evidencias

La recogida de evidencias debe realizarse, en la medida de lo posible, sin utilizar programas del propio sistema investigado.Se proponen utilizar herramientas arrancadas desde soportes externos.

Entre las actuaciones señaladas están:

- Obtener fecha y hora del sistema.
- Realizar una instantánea del estado actual.
- Utilizar comandos de consola.
- Comprobar puertos TCP y UDP abiertos y las aplicaciones que los utilizan.
- Listar usuarios conectados.
- Enumerar procesos activos.
- Revisar la configuración IP.

- Consultar correspondencias MAC.
- Buscar ficheros ocultos o borrados.
- Revisar los registros del sistema.
- Analizar el tráfico de red.
- Realizar copias bit a bit de los discos.

7.4. Tipos de evidencias

El material menciona como evidencias:

- Dispositivos de comunicaciones, como routers, conmutadores y concentradores.
- Registros generados por el sistema, como archivos *log*.
- Registros almacenados en el sistema, incluyendo texto, imágenes y vídeo.
- Registros de servidor, por ejemplo los generados por servidores web como Apache.

7.5. Herramientas de análisis forense

Las herramientas para análisis forense deben permitir examinar procesos, estudiar el estado del sistema y realizar copias bit a bit. El material destaca la conveniencia de utilizar soportes de solo lectura durante la recogida de evidencias.

Entre las herramientas citadas aparecen:

- **The Forensic Toolkit (FTK)** para Windows.
- **The Sleuth Kit y Autopsy** para entornos Unix/Linux y Windows.
- Herramientas distribuidas en formatos *Live*, ejecutadas desde fuera del sistema objeto del análisis.

7.5.1. The Forensic Toolkit

FTK es una colección de herramientas forenses para plataformas Windows. El material indica que permite recopilar información del ataque y generar informes y estadísticas del sistema de archivos.

Algunos comandos citados son:

Comando	Función
`afind`	Busca archivos por tiempo de acceso.
`hfind`	Busca archivos ocultos.
`sfind`	Busca datos ocultos en el disco distintos de los ficheros ocultos.
`filestat`	Muestra atributos de archivos.
`hunt`	Obtiene información sobre usuarios, recursos compartidos y servicios.

7.5.2. The Sleuth Kit y Autopsy

The Sleuth Kit es una colección de herramientas forenses para Unix/Linux y Windows. Entre sus funciones se citan:

- Registrar distintos casos e investigaciones.
- Acceder a estructuras de archivos y directorios, incluidos elementos eliminados.
- Generar líneas temporales de actividad.
- Buscar datos mediante palabras clave.
- Crear notas del investigador.
- Generar informes.

Autopsy proporciona una interfaz gráfica que facilita la consulta de los resultados.

Entre sus funcionalidades se encuentran:

- Análisis de archivos y directorios, incluidos ocultos.
- Búsqueda por palabras clave.
- Búsqueda y ordenación por tipo de archivo.
- Consulta detallada de imágenes.
- Acceso a metadatos y referencias a archivos eliminados.
- Examen de unidades de datos en formato ASCII o hexadecimal.

7.5.3. Herramientas en formato Live

El material señala que, para análisis forense, es conveniente utilizar herramientas que puedan ejecutarse desde fuera del sistema, por ejemplo mediante un *Live CD*.

Se citan:

- **Helix CD**, una distribución Linux basada en Knoppix que permite realizar análisis forense sin modificar el sistema objeto y recuperar evidencias volátiles.

- **Fire Linux**, otra distribución Linux orientada al análisis forense y con herramientas de red, seguridad, análisis de discos y acceso remoto.

Fuente principal

Ministerio de Educación y Formación Profesional. *Adopción de pautas de seguridad informática*. Materiales formativos de FP Online, unidad didáctica de 86 páginas. Documento aportado para la elaboración de estos apuntes.